Semantic Secrets: Security and Privacy of Reconstructable Visual Authentication

Abstract—**Approximate semantic authentication accepts independently reconstructed realizations of an intended concept. Its security depends on the full region of accepted alternatives and on an attacker's ability to reach that region within a finite budget. This planning draft asks whether independently generated visual realizations can produce stable and discriminative canonical graphs, how mandatory and tolerant semantic policies change guessing success, and whether a frozen predicate can be evaluated without exposing reusable templates, offline candidate tests or cross-service linkage. We separate learned perception, deterministic graph compilation, policy derivation, acceptance-region attacks and construction-specific private verification. Existing experiments provide bounded negative evidence: the earlier monolithic extraction path failed its preregistered structured-output gate, without establishing universal extractor impossibility. A modular compiler and experiment harness are implemented, and 240 capability images exist; final naturalistic references and formal v3 evaluation remain pending. This document reports no validated v3 authentication system, guessing resistance, private protocol or human-memory result. It organizes the security questions, evidence requirements and limitations for an original research study.**

Index Terms—**authentication, semantic reconstruction, acceptance regions, guessing attacks, private verification**

1. Introduction

Planning draft, 26 October 2026. This evidence-bounded manuscript is under preparation for EuroS&P 2027; it is not a submission-ready completed system.

Exact-secret authentication can be idealised as accepting a singleton, $\mathcal{A}(s) = \{s\}$. Semantic authentication replaces exact reproduction with approximate reconstruction: different prompts and visual realizations of one intended concept may need to authenticate as equivalent. It therefore induces a fuzzy set $\mathcal{A}(S) = \{S' : \mathsf{Accept}(S, S') = 1\}$. Benign reconstructions must vary, yet every tolerated variation can enlarge the set an attacker may submit. Too strict a predicate rejects independent same-concept reconstructions; too tolerant a predicate gives attackers more accepted alternatives.

This yields a central security question: can independently reconstructed visual concepts produce stable and discriminative canonical credentials whose complete acceptance region remains sufficiently resistant to realistic and AI-assisted guessing? It also yields a separate privacy question. A deterministic graph, policy, protected record, or transcript may reveal semantic content, support database-only candidate testing or adaptive probing, and link reuse across accounts or services. Secure computation may hide the comparison while leaving the accepted region easily enumerable; good discrimination may coexist with template leakage.

We study a prospective client-side pipeline in which an intended concept is reconstructed through free natural language, a local generator produces an independent visual realization, and local perception plus deterministic compilation produce canonical semantics. The strongest target sends neither prompt, image, observation, plaintext graph, nor raw embedding to the authentication infrastructure. The generator serves as a semantic reconstruction and normalisation boundary, not as a memorability device.

No participant study is planned. Researcher-authored concepts and reconstructions can measure only technical semantic reconstruction stability. They cannot establish memorability, recall, usability, preference, accessibility, natural credential choice, real-world authentication time, superiority to passwords or passkeys, or that images are easier to remember. The primitive is not presumed to replace passwords: standalone, second-factor, policy-constrained, restricted-use, negative/measurement, and stop outcomes remain possible.

Prospective contribution boundary.. C1 tests technical reconstructability; C2 tests the incremental value of system-derived mandatory/tolerant policies; C3 measures finite-budget acceptance-region security; C4 asks for construction-specific private verification. C1/C2 enable the principal security/privacy questions. A final paper must report only contributions supported by frozen evidence. A broader security-or-privacy venue scope does not itself establish a mechanism or remove the separate privacy question.

2. Background and Closest Work

VSA [1] is the closest mandatory baseline. It enrols a reference image, extracts objects, CLIP-derived attributes, quantities, visibility, and 2×2 quadrant location, and lets a user select two or three semantic facts plus quantity operators. Authentication uses an arbitrary satisfying image and an additional password. VSA serialises canonical semantic tokens, evaluates Flexible Range Logic conjunctions, hashes most semantic fields together with the password using SHA-256, and retains quantity/operator metadata separately.

These features remove image-independent visual-semantic authentication, VLM extraction, canonical tokens, object, attribute, count, and quadrant rules, flexible quantity policies, conjunction, and user-selected semantic policy from our novelty space. We require two fair baselines: (i) VSA's semantic-policy component for functional discrimination and (ii) the full semantic-plus-password hash architecture for security comparison. We must not compare a semantic-only system directly with

VSA's claimed combined semantic-plus-password space as though the credentials were equivalent.

VSA calls its hash binding server-opaque and explicitly weaker than strict zero knowledge. It acknowledges small semantic inputs and fast SHA-256 offline guessing, recommending Argon2id with a user-specific salt. Its COCO-based positive FRR samples are automatically selected from cached detections rather than independently re-inferred. It reports no human study and leaves Semantic Relationship Logic to future work. It does not target private/unlinkable verification.

SemanticLock uses semantically linked image tokens and story structure for graphical authentication [2]. PassStyles [3] and Omokage [4] use StyleGAN-generated changing face candidates and recognition criteria, preventing broad "first semantic", "first generative", or "first changing-image" authentication language. Adaptive score-guided verifier search is likewise established [5]. The P8 review found no verified source combining free-language independent text-to-image reconstruction and fresh typed extraction with a system-derived policy, finite-budget semantic attacks, and construction-specific private/domain-separated verification. Gate V2-N passed for that scoped question only; this is not an exhaustive absence or first claim.

The v3 shortlist is grounded in prior visual-understanding work. Grounding DINO produces open-set, language-conditioned boxes [6]; SigLIP 2 provides contrastive vision-language encoders for closed-label scoring and localization-oriented transfer [7]; and EGTR exposes object, relation, and connectivity predictions from a DETR-based graph model [8]. SGTR [9] remains the historical v3.0 graph candidate. The newer autoregressive ROBIN/Synthetic Visual Genome path [10] was audited but rejected because generated graph text and semantic label mapping would reintroduce structured-generation risk. Visual Genome illustrates the dense annotation problem and its dataset limitations [11]. These are established perception components, not authentication or privacy contributions.

3. System and Threat Model

The trusted client receives a reconstruction prompt, generates an image, observes it, compiles a graph and derives policy. An authentication service stores the eventual construction-specific record and enforces authorized sessions. A separately administered privacy/key service or threshold shares remain candidate architectures, not selected deployment assumptions. The strongest target keeps prompts, transient images, observations, plaintext graphs, raw embeddings and exact scores on the trusted client.

Algorithms, model identities, vocabulary, canonicalization and thresholds are public. An adversary may control an authenticating client, submit adaptive candidates, obtain a named database snapshot, compromise declared services/keys, or observe transcripts. Each claim names the view, knowledge, budget and success event. Knowledge ranges from generic public information (K_0), through source-frequency information (K_1) and partial target facts (K_2), to strong near-secret information (K_3). An attacker wins with any accepted alternative. Rate limits are online assumptions, not protection for a stolen offline verifier. Total-compromise protection is not presumed.

Normal verification should reveal a context-bound decision and declared metadata. Scores, matched anchors, policy shape, message lengths, timing and distinguishable failure paths require separate leakage analysis. Client compromise and unavailable components delimit eventual guarantees; no silent weaker fallback is permitted.

3.1. Research Questions

Together these questions ask whether technical reconstruction works, whether its necessary tolerance creates an acceptable attack surface, whether that predicate can be evaluated privately, and whether the trusted-client design is computationally practical. They do not evaluate human memory or claim password replacement.

RQ1—Reconstruction. Can independently generated images representing the same intended visual concept produce stable canonical semantic credentials?
RQ2—Policy-aware matching. Can a system-derived $S = (M, T)$ policy preserve legitimate technical reconstruction variation while rejecting security-critical semantic differences?
RQ3—Acceptance-region security. How vulnerable is the induced accepted region under K_0–K_3 attackers and finite budgets?
RQ4—Template/privacy leakage. What semantics can be inferred from stored records, policies, and authentication transcripts under named compromise views?
RQ5—Private verification. Can the frozen policy be evaluated while hiding the semantic credential and resisting practical database-only validation and cross-domain linkage under stated assumptions?
RQ6—Practicality. What computation, bandwidth, latency, storage, trust, and deployment assumptions are required?

4. Reconstruction and Semantic Design

4.1. Observation and Deterministic Compilation

Let C denote an intended semantic concept and P a free-form reconstruction interface. Different expressions may aim at the same concept—for example, "a cat beside a red car" and "a feline next to a crimson automobile." The hypothesis is not exact prompt reproduction. With generator G and randomness r,

$$I = G(P, r), \tag{1}$$

where I is a transient, independently generated reconstruction medium. Pixels do not contribute credential entropy merely because generation is stochastic. A versioned modular pipeline produces probabilistic visual evidence

$$O = \mathsf{Observe}(I), \tag{2}$$

and a deterministic semantic compiler produces the security-sensitive representation

$$S = \mathcal{C}(O) \tag{3}$$

or a typed failure. Models infer bounded evidence; code owns schema, identifiers, duplicates, inverse normalization, derived counts and geometry, ordering, and serialization. Thus the prompt is an interface, the image is a transient medium, observations are evidence, and the canonical graph is the representation used by the predicate. Operationally, the security surface is the complete set of candidate semantics the verifier accepts.

This framing differs from treating direct text embeddings or a single generated image as the authentication object. It also creates a falsifiable condition: if independent generation and fresh extraction do not preserve security-relevant structure, the visual reconstruction hypothesis fails.

4.2. Policy and Reference Predicate

We provisionally represent S as a typed graph

$$S = (V, E_S, A, C_S), \tag{4}$$

where V contains entities, E_S typed actions/relations, A attributes, and C_S counts and scene/context facts. A deterministic, versioned policy derivation function produces

$$\Pi(S) = (M, T), \tag{5}$$

where M contains mandatory security anchors and T contains secondary facts with bounded tolerance. The primary non-human study will not ask users to nominate M or T. Selection must be frozen from independent semantic rationale, training-only statistics, extractor reliability, attacker-frequency evidence, and protocol compatibility.

A P8-frozen reference functionality has the form

$$\begin{aligned} \mathsf{Accept}_{\mathrm{ref}} = {} & \mathsf{MandatoryOK}(M, M') \\ & \wedge [\mathsf{TolSim}(T, T') \geq \tau]. \end{aligned} \tag{6}$$

The v3 observation/compiler contract is specified in `docs/formal_specification_v3.md`. Its broad candidate language L_{visual} contains entities, attributes, actions/interactions, derived geometry/counts, and scenes. A type enters $L_{\mathrm{cred}} \subseteq L_{\mathrm{visual}}$ only after independent capability evidence passes in both controlled and naturalistic strata. Actions and interactions are independently gated: neither is required nor silently discarded. The M/T notation and policy split are preserved but are not implemented or tuned in P9-v3A and are not claimed as standalone novelty.

5. Evaluation Design and Reproducibility

The execution order is deliberately staged.

Novelty and preregistration.. P8 completed a focused primary-source novelty refresh and froze graph tasks, controlled concepts, splits, capability screening, policy derivation, attack budgets, uncertainty, and numeric gate thresholds. It performed no model acquisition, dataset acquisition, v2 inference, sealed-v1 access, or cryptographic implementation.

Representation before authentication.. P9-v2 screened two preregistered monolithic extractors on 96 controlled images. Both failed the schema-validity prerequisite under exact logical futility, and reconstruction was not executed. P9-v3A is a new architecture/preregistration phase, not a repair. It freezes $I = G(P, r)$, $O = \mathsf{Observe}(I)$, $S = \mathcal{C}(O)$ and $(M, T) = \Pi(S)$; two modular pipelines; a new 240-image capability design; compiler/perception metrics; and Gates V3-A1/V3-A2. The pre-output v3.1 addendum changes only prospective suitability details: EGTR replaces SGTR, support is opportunity-based, and installed GPU capacity is not confused with measured pipeline consumption. Neither phase runs a model.

Policy and attackers.. P10 compares dense similarity, global fuzzy overlap, a feasible VSA-style policy, and the proposed system-derived M/T policy. P11 evaluates the full acceptance region under budgeted attackers before any cryptographic implementation.

Private verification.. Only a constructive semantic-security gate permits P12 to define the ideal functionality and compare mature constructions. Minimal POCs precede selection. The selected protocol is then evaluated for reference correctness, leakage, offline validation, compromise, linkage, and cost.

Practicality.. RQ6 measures client-side generator, perception, compiler, and protocol costs rather than assuming them. P9-v3B has not established actual resource requirements. A powerful research GPU is experimental infrastructure, not automatically part of the intended deployment architecture. If trusted-client execution is impractical, the valid result is a deployment limitation, restricted-use outcome, failed practicality gate, or negative finding—not migration of secret-bearing prompt, image, observation, or graph processing to an untrusted cloud.

Baselines.. Planned baselines include direct-text processing, dense visual/text similarity, global fuzzy semantic overlap, VSA semantic-policy behaviour, the full VSA binding model where reproducible, plaintext/hash records, and relevant mature private-matching constructions. Any inaccessible or underspecified VSA behaviour will be documented rather than guessed.

5.1. Modular Capability and Independent Reconstruction

The v2 failure conflated serialization correctness with semantic correctness. A model can describe an image correctly yet truncate JSON, or emit valid JSON containing false facts. V3 therefore makes the observation object explicit: detections carry category, normalized box, component-local confidence and revision; attributes, unary actions, binary interactions, and scene hypotheses reference those detections and retain provenance, abstention, failure, latency and memory events. Confidence values are not compared across components or treated as calibrated probabilities.

The deterministic compiler validates versions, labels, boxes and references; resolves same-category duplicates under a frozen IoU/tie-break rule; assigns canonical identifiers; derives counts and spatial relations; normalizes inverse edges; and serializes sorted UTF-8 JSON. It returns a valid graph or a valid typed failure, never malformed

output. At least 320 exact tests must pass with 100% oracle agreement, schema validity and byte repeatability. One compiler invariant failure blocks V3-A1 regardless of perception scores.

The final two pipelines test distinct assumptions. The first combines Grounding DINO Tiny with SigLIP 2 Base for entity localization and closed-label crop, pair-crop and scene scoring; pair-crop relation classification is an experimental compositional hypothesis, not an established relation detector. The second combines EGTR(VG) graph-native object/relation/connectivity tensors with SigLIP 2 attributes and scenes. Exact revisions, checkpoint identities, acquisition hashes, adapters, label intersections, development-only thresholds, and failure rules are pre-registered. Any documented dedicated research GPU may be used, but measured complete-pipeline peak VRAM remains at most 24 GiB and peak RSS at most 32 GiB; median latency remains at most 30 seconds/image and p95 at most 60 seconds/image. Installed capacity is not a gate and cannot raise consumption limits.

P9-v3B has 120 controlled geometric/composited fixtures and 120 naturalistic images requested from a public SD-Turbo endpoint under the prospective v3.4 generation amendment. Actual endpoint weights/settings are unattested; these images are not described as reproduction of the pinned local generator. Final-image naturalistic references and the ground-truth freeze remain pending. Each stratum has 24 semantic families split 12/12 between development and validation, five images per family. Project-authored closed-label reference scene specifications, normalized reference boxes, support opportunities, and provenance are frozen before model output and are never derived from predictions; P9-v3B has no human participants or annotators. The v3.1 primary gate types are entity, colour, count, binary interaction, and geometry relation; each has at least 60 positive and 60 applicable-negative validation opportunities per stratum without requiring more than two to four visible entities per image. Other types remain exploratory at 30/30 and are 'not_gate_evaluable', not post-hoc passes or failures of unrelated types. A type must also pass precision, recall, F1, coverage and family-level uncertainty separately in both strata. Gate V3-A1 still requires one complete pipeline with eligible entity plus two further types, including a structural type; cross-pipeline union is forbidden.

P9-v3C is future and requires a separate reconstruction freeze. Gate V3-A2 requires eligible enrolment, FRR, targeted-neighbour FAR, random FAR, same/near AUC, and a material paired M/T improvement over the strongest baseline. Passing it would establish only technical reconstruction feasibility. P10 remains blocked until V3-A2; cryptography remains further downstream.

5.2. Gate Order and Evidence Isolation

Gate V2-N passed with narrowing. Gate V2-A is the immutable failed monolithic path. The explicit new-version path uses V3-A1 modular extraction viability and V3-A2 independent reconstruction viability before the retained V2-B policy, V2-C acceptance-region, V2-D private-functionality, V2-E protocol/privacy, and V2-F end-to-end gates. No later cost may bypass an earlier failure. Valid outcomes include standalone authentication, second factor, policy-constrained credential, measurement/negative contribution, or stop.

6. Available Evidence and Unresolved Validation

6.1. Historical Monolithic Extractor Result

The P9 capability manifest contains 64 development and 32 validation fixtures, equally divided between procedural/composite and researcher-authored synthetic-raster scenes. It accesses no participant or sealed-v1 data. Moondream2 at revision prefix `9a7d40240508` emitted no JSON on formal validation fixture `cap-v2-064` in 157.57 seconds with 4.58 GiB peak process RSS. SmolVLM2-2.2B-Instruct at revision prefix `c0a7af506d0f` emitted malformed, truncated JSON in 392.10 seconds with 5.62 GiB peak RSS. The artifact records both complete immutable revisions.

The preregistration did not specify an early-stop rule. After separate plumbing smoke and before formal validation output, we implemented exact logical futility: because all checks are conjunctive, one invalid result makes the 98% schema-validity check impossible even if all remaining fixtures pass. This procedural deviation cannot create a pass, but it limits the negative evidence. We did not estimate full atom F1, bootstrap intervals, determinism, structured error strata, or full-set latency medians. We made no candidate replacement, prompt/output repair, fine-tuning, or authentication-outcome selection.

6.2. Current Modular Preparation

The 26 October local audit passed 421 core software tests, including the 320 compiler invariant cases. Six remote-generation transport tests passed with mocked service behavior. These establish tested engineering properties, not perception accuracy, reconstruction success or authentication security. The audit also reproduced an entity-scoring defect: one predicted object can receive credit for multiple overlapping reference objects even when one-to-one correspondence assigns only one. Calibration and validation share this function. Moved manual walkthroughs retain incorrect repository-root paths. Both defects remain unresolved evaluation blockers; passing existing tests does not establish evaluator correctness.

All 240 images decode at 512×512, have distinct file hashes and match the saved inventory. Retained remote-response and PNG-conversion hashes agree. The 120 controlled reference records pass existing structural/count/geometry/support audits. No completed naturalistic reference record, final capability manifest, support-opportunity table or ground-truth freeze is available. File integrity and construction audits do not establish semantic correctness. No formal v3 perception metric, fitted threshold, eligible credential language or gate result is reported.

6.3. Formative v1 Results

The completed P0–P7 programme evaluated a different system, `visual-semantic-pipeline-v1`. P6's training-selected weighted matcher had validation FRR

20.8%, targeted-neighbour FAR 75.0%, and random FAR 3.0%; all tested representations failed the original gate. Twelve v1 test families remain sealed. P7 then found no uncertainty-supported material benefit from the tested SD-Turbo/Florence/SigLIP image pathways and removed that image stage from the v1 authentication core.

These are immutable formative negative results, not v2 measurements. They motivate explicit security anchors and independent capability screening but may not tune the v2 policy, representation, data, or gates. The v2 hypothesis requires new identifiers, preregistration, and evidence.

7. Acceptance-Region Security and Private Verification

7.1. Budgeted Semantic Attacks

For an enrolled state, define the accepted region

$$\mathcal{A}(S, M, T) = \{(S', M', T') : \mathsf{Accept}_{\mathrm{ref}} = 1\}. \quad (7)$$

An attacker succeeds by finding any member, not by recovering the enrolled prompt, image, or exact graph. Acceptance-region reachability is therefore the security object rather than a usability feature. We distinguish:

- K_0: generic public knowledge and random candidates;
- K_1: population or frequency knowledge without target facts;
- K_2: partial target-specific semantic information;
- K_3: strong near-secret information.

For strategy Q, budget B, knowledge K_i, and observable view V, the primary quantity is

$$\mathsf{Succ}(Q, B, K_i, V) = \Pr[\exists j \le B : q_j \in \mathcal{A}(S, M, T)]. \quad (8)$$

The evaluation should report success@1, @5, @10, and $@B$, guesses to success, duplicate policy, uncertainty, and cost. Random FAR is only one distributional statistic. Frequency, targeted neighbours, partial knowledge, LLM/VLM/generator assistance, and adaptive semantic search may produce different risk. AI-assisted password guessing is established prior art [12]; this project must contribute a semantic acceptance-region analysis rather than the general idea of using a model to guess.

7.2. Construction-Specific Privacy

The protected record is abstractly

$$R = \mathsf{Protect}(S, M, T, \mathsf{account}, \mathsf{domain}, \mathsf{version}). \quad (9)$$

A later protocol should reproduce the frozen plaintext decision while revealing no more than its declared output and metadata. Candidate goals are:

- template confidentiality against semantic recovery or accepted-equivalent reconstruction;
- resistance to cheap database-only candidate validation under an exact stolen-record view;
- policy privacy for anchor identities, operators, weights, thresholds, and graph shape;
- unlinkable, domain-separated records and transcripts;
- transcript minimisation, replay/session binding, and explicit adaptive-query leakage;
- containment under named database, server, key/share, collusion, and total-compromise states.

Established fuzzy extractors [13], fuzzy aPAKE [14], OPRFs [15], OPAQUE [16], exact PSI [17], [18], fuzzy PSI/private biometric matching [19], [20], committed PSI [21], private fuzzy-record computation [22], private graph operations [23], and homomorphic vector matching [24] are candidate foundations, not novel primitives. Raw learned representations are not automatically private; embedding leakage is an explicit concern [25]. Protected-template unlinkability and irreversibility must be attacked rather than inferred from an encoding [26].

Semantic correctness and cryptographic privacy are independent. FAR/FRR do not prove template, policy, transcript, or linkage privacy; private computation does not repair an easily guessed acceptance region.

8. Limitations and Practicality

The controlled, English-language, closed-vocabulary design measures technical behavior on authored concepts. It does not estimate natural credential choices, population entropy, memorability, usability, accessibility or superiority to passwords/passkeys. Generalization beyond synthetic controlled scenes and sampled naturalistic generations requires evidence. The public generation endpoint does not attest exact weights, settings, fallbacks or reproducibility. A local deployment cannot inherit its feasibility or performance.

Compiler determinism does not guarantee that two images produce the same semantics. Missing detections, role binding, relation ambiguity, abstention and pipeline failure can change reliability and the accepted region. Same-image repeatability and independent-concept reconstruction are distinct. Correct the scoring defect prospectively before interpreting metrics. Neither thresholds nor policies may be repaired against held-out outcomes.

Measure trusted-client generator, perception, compiler and protocol latency, memory, storage, bandwidth and trust assumptions separately. A research GPU does not demonstrate client practicality. Secret-bearing processing may not move to an untrusted cloud to rescue feasibility. Preserve failed gates and negative findings, or pursue a separately justified research scope; do not imply successful authentication or private verification.

9. Proactive Prevention of Harm

A permissive semantic region can enable unauthorized access; records or transcripts can expose concepts or link accounts. Publishing attack tools creates dual-use risk. Restrict experiments to synthetic/local accounts and public, project-authored capability fixtures. Do not target real services or identify prompt contributors. Keep private authentication inputs local. Minimize retained sensitive data and audit release contents, model/data terms and provenance before publication. The public capability-generation API receives no authentication secret under this study boundary.

No human-subject study is authorized and no external ethics approval is claimed. Reassess ethics and consent before participant data or human-behavior work. Explain

synthetic-data limitations and unsupported claims so a prototype is not mistaken for a validated authentication product.

10. Data Availability

The planned artifact will contain permitted code, frozen configurations, manifests and hashes, compiler cases, provenance, raw-to-aggregate processing and deterministic figure scripts. Release data or regeneration instructions only where redistribution/model terms permit, and explain restrictions rather than promising unlicensed weights or data. Code licensing and final release rights remain to be resolved before publication. Reviewer access must use anonymous hosting. No anonymous artifact URL or public release is claimed here.

11. Conclusion

Approximate reconstruction makes the full semantic acceptance region a security object. The research asks whether that region preserves legitimate technical variation while limiting budgeted attacker success, and whether its predicate can separately be evaluated with bounded template, policy and linkage leakage. Historical negative findings remain unchanged. The modular compiler and capability data provide preparation; reference completion, evaluator correction and every formal security/privacy gate remain evidence requirements. Measured results must determine the defensible contribution and deployment scope.

Acknowledgments: AI Use

OpenAI ChatGPT/Codex assisted substantive drafting and restructuring throughout Sections 1–11, and research-code/documentation preparation. Stability AI SD-Turbo was requested through a public endpoint for the naturalistic capability images in Sections 5 and 6; actual hosted weights/settings are unattested. Final provenance must identify any additional AI-generated material. Perception candidates are experimental components, not validated sources of ground truth. Authors remain responsible for checking all text, code, citations, labels and results. This anonymous disclosure must be checked against the final tool/use inventory before submission.

References

[1] P.-s. Jeong, "Design and security validation of image-agnostic visual semantic authentication (VSA) framework based on vision-language model," *Journal of The Korea Institute of Information Security and Cryptology*, vol. 36, no. 3, pp. 935–948, Jun. 2026, peer-reviewed article in Korean.

[2] I. Olade, H.-N. Liang, and C. Fleming, "Story-based authentication for mobile devices using semantically-linked images," *International Journal of Human-Computer Studies*, vol. 171, p. 102967, Mar. 2023.

[3] H. Matsuzaki, T. Maekawa, M. Imai, and K. Ishii, "PassStyles: Graphical authentication using mixed face styles," *IEEE Access*, vol. 13, pp. 165 411–165 428, 2025.

[4] ——, "Omokage authentication: A graphical authentication system using mixed visual resemblance," *IEEE Access*, vol. 14, pp. 93 009–93 026, 2026.

[5] M. Martinez-Diaz, J. Fierrez, J. Galbally, and J. Ortega-Garcia, "An evaluation of indirect attacks and countermeasures in fingerprint verification systems," *Pattern Recognition Letters*, vol. 32, no. 12, pp. 1643–1651, 2011.

[6] S. Liu, Z. Zeng, T. Ren, F. Li, H. Zhang, J. Yang, Q. Jiang, C. Li, J. Yang, H. Su, J. Zhu, and L. Zhang, "Grounding DINO: Marrying DINO with grounded pre-training for open-set object detection," in *Computer Vision – ECCV 2024*. Springer, 2024. [Online]. Available: https://arxiv.org/abs/2303.05499

[7] M. Tschannen, A. Gritsenko, X. Wang, M. F. Naeem, I. Alabdulmohsin, N. Parthasarathy, T. Evans, L. Beyer, Y. Xia, B. Mustafa, O. Hénaff, J. Harmsen, A. Steiner, and X. Zhai, "SigLIP 2: Multilingual vision-language encoders with improved semantic understanding, localization, and dense features," 2025, preprint. [Online]. Available: https://arxiv.org/abs/2502.14786

[8] J. Im, J. Nam, N. Park, H. Lee, and S. Park, "EGTR: Extracting graph from transformer for scene graph generation," in *Proceedings of the IEEE/CVF Conference on Computer Vision and Pattern Recognition*. IEEE, 2024, pp. 24 229–24 238. [Online]. Available: https://openaccess.thecvf.com/content/CVPR2024/html/Im_EGTR_Extracting_Graph_from_Transformer_for_Scene_Graph_Generation_CVPR_2024_paper.html

[9] R. Li, S. Zhang, and X. He, "SGTR: End-to-end scene graph generation with transformer," in *Proceedings of the IEEE/CVF Conference on Computer Vision and Pattern Recognition*. IEEE, 2022, pp. 19 486–19 496.

[10] J. S. Park, Z. Ma, L. Li, C. Zheng, C.-Y. Hsieh, X. Lu, K. Chandu, Q. Kong, N. Kobori, A. Farhadi, Y. Choi, and R. Krishna, "Synthetic visual genome: Dense scene graphs at scale with multimodal language models," in *Proceedings of the IEEE/CVF Conference on Computer Vision and Pattern Recognition*. IEEE, 2025. [Online]. Available: https://openaccess.thecvf.com/content/CVPR2025/html/Park_Synthetic_Visual_Genome_CVPR_2025_paper.html

[11] R. Krishna, Y. Zhu, O. Groth, J. Johnson, K. Hata, J. Kravitz, S. Chen, Y. Kalantidis, L.-J. Li, D. A. Shamma, M. S. Bernstein, and L. Fei-Fei, "Visual genome: Connecting language and vision using crowdsourced dense image annotations," *International Journal of Computer Vision*, vol. 123, pp. 32–73, 2017.

[12] J. Rando, F. Perez-Cruz, and B. Hitaj, "PassGPT: Password modeling and (guided) generation with large language models," in *Computer Security – ESORICS 2023*, ser. Lecture Notes in Computer Science, vol. 14347. Springer, 2023, pp. 164–183.

[13] Y. Dodis, R. Ostrovsky, L. Reyzin, and A. Smith, "Fuzzy extractors: How to generate strong keys from biometrics and other noisy data," *SIAM Journal on Computing*, vol. 38, no. 1, pp. 97–139, 2008. [Online]. Available: https://www.cs.bu.edu/~reyzin/fuzzy.html

[14] A. Erwig, J. Hesse, M. Orlt, and S. Riahi, "Fuzzy asymmetric password-authenticated key exchange," in *Advances in Cryptology – ASIACRYPT 2020*. Springer, 2020. [Online]. Available: https://research.ibm.com/publications/fuzzy-asymmetric-password-authenticated-key-exchange

[15] A. Davidson, A. Faz-Hernandez, N. Sullivan, and C. A. Wood, "Oblivious pseudorandom functions (OPRFs) using prime-order groups," RFC Editor, RFC 9497, Dec. 2023, informational RFC; CFRG/IRTF consensus document. [Online]. Available: https://www.rfc-editor.org/rfc/rfc9497.html

[16] D. Bourdrez, H. Krawczyk, K. Lewi, and C. A. Wood, "The OPAQUE augmented password-authenticated key exchange (aPAKE) protocol," RFC Editor, RFC 9807, Jul. 2025, informational RFC; CFRG/IRTF consensus document. [Online]. Available: https://www.rfc-editor.org/rfc/rfc9807.html

[17] M. J. Freedman, K. Nissim, and B. Pinkas, "Efficient private matching and set intersection," in *Advances in Cryptology – EUROCRYPT 2004*, ser. Lecture Notes in Computer Science, vol. 3027. Springer, 2004, pp. 1–19. [Online]. Available: https://crypto.stanford.edu/portia/pubs/articles/FNP227785321.html

[18] B. Pinkas, T. Schneider, G. Segev, and M. Zohner, "Phasing: Private set intersection using permutation-based hashing," in *24th USENIX Security Symposium (USENIX Security 15)*. Washington, DC: USENIX Association, Aug. 2015, pp. 515–530. [Online]. Available: https://www.usenix.org/conference/usenixsecurity15/technical-sessions/presentation/pinkas

[19] E. Uzun, S. P. Chung, V. Kolesnikov, A. Boldyreva, and W. Lee, "Fuzzy labeled private set intersection with applications to private real-time biometric search," in *30th USENIX Security Symposium (USENIX Security 21)*. USENIX Association, Aug. 2021, pp. 911–928. [Online]. Available: https://www.usenix.org/conference/usenixsecurity21/presentation/uzun

[20] E.-O. Blass and G. Noubir, "Assumption-free fuzzy PSI via predicate encryption," in *35th USENIX Security Symposium (USENIX Security 26)*. Baltimore, MD: USENIX Association, Aug. 2026. [Online]. Available: https://www.usenix.org/conference/usenixsecurity26/presentation/blass

[21] A. Goel, P. Miao, P. V. L. Pham, and S. Singh, "PICS: Private intersection over committed (and reusable) sets," in *35th USENIX Security Symposium (USENIX Security 26)*. Baltimore, MD: USENIX Association, Aug. 2026. [Online]. Available: https://www.usenix.org/conference/usenixsecurity26/presentation/goel

[22] K. Han, S. Kim, and Y. Son, "Private computation on common fuzzy records," *Proceedings on Privacy Enhancing Technologies*, vol. 2025, no. 1, pp. 567–583, 2025.

[23] P. Li, F. Zhou, Z. Xu, and Y. Li, "Privacy-preserving graph operations for mobile authentication," *Wireless Communications and Mobile Computing*, 2020.

[24] S. Martin, N. Koirala, H. Berens, T. Rozgonyi, M. Brody, and T. Jung, "HyDia: FHE-based facial matching with hybrid approximations and diagonalization," *Proceedings on Privacy Enhancing Technologies*, vol. 2025, no. 4, pp. 585–604, 2025.

[25] C. Song and A. Raghunathan, "Information leakage in embedding models," in *Proceedings of the 2020 ACM SIGSAC Conference on Computer and Communications Security*. Association for Computing Machinery, 2020, pp. 377–390.

[26] M. Gomez-Barrero, C. Rathgeb, J. Galbally, C. Busch, and J. Fierrez, "Unlinkable and irreversible biometric template protection based on bloom filters," *Information Sciences*, vol. 370–371, pp. 18–32, 2016.